

SAST Report

Scholarstika
May10, 2026

Project Name: Scholarstika

Date: 24.01.2026

**Prepared by: Cybersecurity Department
Betopia Limited**

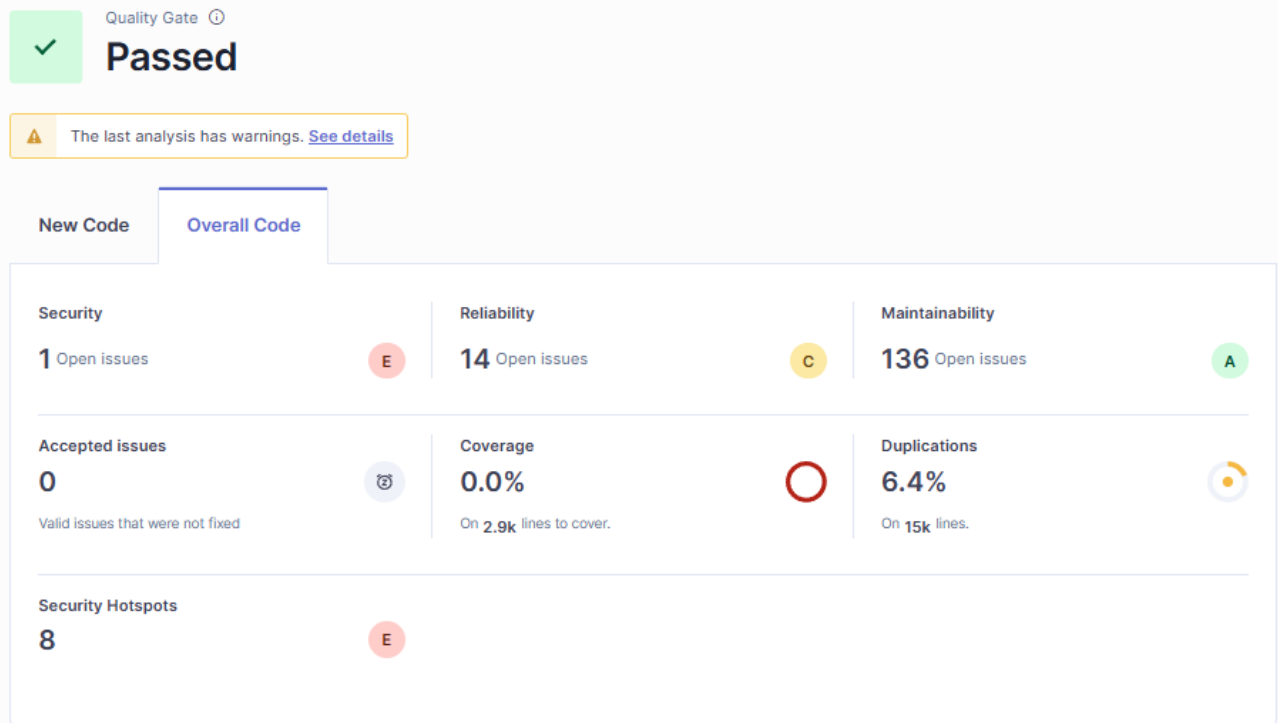
This report presents the results of a Static Application Security Testing (SAST) analysis conducted using SonarQube on the “scholarstika” project. The analysis confirms that the

application successfully passed the Quality Gate, indicating no critical security vulnerabilities in the current code base. While the security posture is strong, some improvements are recommended in code reliability, maintainability, test coverage, and code duplication to enhance long-term stability and scalability.

SAST Tool & Methodology

Content:

- SonarQube was used to perform static code analysis
- Code was analyzed without execution
- Focus areas:
 - Security vulnerabilities
 - Code reliability
 - Maintainability
 - Code duplication
 - Security hotspots



Security Issues:

Make sure this service account key gets revoked, changed, and removed from the code.

Google Cloud service accounts keys should not be disclosed [secrets:S6335](#)

Line affected: L6 • Effort: 30min • Introduced: 13 hours ago

Open ▾

Not assigned ▾

cwe

Where is the issue?

Why is this an issue?

How can I fix it?

Activity

More info

3

4

5

6

```
project_id: "timothy-d072a",
private_key_id: "63013f951354128887c6c8de30e92d673c0e76a5",
private_key:
"
-----BEGIN PRIVATE KEY-----
\nMIIEvQIBADANBgkqhkiG9w0BAQEFAASCBKcwggSjAgEAAoIBAQC20E8BZ9GPQuRp\nn3QZL2xm085Qs5xwM0sJ03CqE7+hUxvVARKUj7G8IU5z0euDHEZCnYeggRdwvAX1\nkn
SDKP+XWo3T+6tt6U3ehckrMzlv3AG2tjTCK0yLV279Fuf6ynW3mqYvJDfQtyuq\nnPrhwkHCz8kDCVNM4yggdHONk60hRsnzNXs8ghwK+2YAoXU57rELf8Hn8e3kZhaMj\nn69n2KT
aSs2QfJLEgPazhuITX6Iwdk0/0vroA1M675CuHLJqWQubKa0cdvp7VBXW\nnF0DEx+FqnXw0rL83PNwuFk9nV397qeLmsdoVCFsGF2P8Tb81qYg9me02z09hdesh\nnEAWqVOETAg
MBAACggEAUJ52VnjEKtEx7GXj6hJmFoJNXJOMPenCinXn+gsaPxpq\nnLPAedr6w3ACbDPqCzMxixZkFX+ZbPQ77jhayNlv/K+KF5F1wu9VBxJPsfXWjVfd\nnIgPjcqW91Le2UP
HBVD7cr48H1Hy65lpsLOOKFPi8Wh+sAoCxpPsFL/QjcHV8Ugj\nnK+yGrMcUudNUkut1QTXFJYXtrgFuFFCSNaMkvKyNvkFnAVIqjAsRtvmUH820d6Nh\nn5MNS8HaETntV1hyQdY
i1avg400rdkDTt+pj+IURhp0MyIjn5FF9wva2djA5u8ze\nn+hVK0dZq8Hz1c0j3uDP0RFQ5+Y3FXrn+h+SrhLXHQB8g007KTq/94eJlgh9FW1\nn5+1oYeAraunJnvWj5l1a1
KEz+D0hsTqAzYGomyHCm60L1mQ1o2ssbYeWN15PHLL\nn0Qj7rw6fV66YuxIzwaRzCQTQf1iG03F0zLxdXFix48cj0uL9PM8Jj3TDeLU/eVCs\nn8gLUGdkThXjvG9MC00mqtJb2jw
KBgQC6Vfpc6nnuuDqgvJZGP8x9s0yP4c0znuLw\nng0A40afyW69LyC/cIOHKbSoftcNDAAM7bV/FI8HpYc7ET/Ky+mGrq2G7aMKFEBK\nnXwH80c/oG7uCHTVRVlRAEbSF/u0jxo
eyELM8bsua80YjCvL0HgLSH01F2d71/UnT\nnt2Afr2gvPQKBgBHI0YCd5dq8bDxbMDZFyek68MU0LL85oenLQPDW6GC+1wvIPuj5\nnKwCn30gwVON8NrsdtYoi6uH7KLMMtJPvH8
LSq29cpd/qXr+LVjly0yih426uLScHb\nn07rgbucpMwAP/kIvq/jhT0MHgM11qMCVQd4CH0goywVLkwT105Vic83BAoGAak1a\nng1+RKEsZx1FP0cxz0NJP18A4VnjCze6stjRo3
+Fzk/wksaRgg6cTFPrGfP0RSBf\nnhtd8miLcvyncBsnF8/uf4/X2TFC3rPFTcvJ0tan8kyRtJ8PI8nQnVLP\nRVHeR6Lf0\nnq0LcZow//oXkjMNUsh0HfC4LMLLLIuZehDUBbtECgY
EAhDziwix06UD00ESY2Jrs\nn0ZzAo+VBgSFLroDq7avM6r/U1XVDIpc7FHHxVTsgXAXy66gTn2HrVfDeZG0i6+6\nnsL2o9orLeZe3co2jpvrcTearXyPEi0cm36htlnTMybZ3
3LaAf1M7Cuw4LCmoxX\nnwzyHpMiXV7mLCs+KDCg29E=\nn-----END PRIVATE KEY-----\n
"
```

Make sure this service account key gets revoked, changed, and removed from the code.

7

8

9

10

11

12

13

14

```
client_email: "firebase-adminsdk-fbsvc@timothy-d072a.iam.gserviceaccount.com",
client_id: "116729388423226321861",
auth_uri: "https://accounts.google.com/o/oauth2/auth",
token_uri: "https://oauth2.googleapis.com/token",
auth_provider_x509_cert_url: "https://www.googleapis.com/oauth2/v1/certs",
client_x509_cert_url:
"https://www.googleapis.com/robot/v1/metadata/x509/firebase-adminsdk-fbsvc%40timothy-d072a.iam.gserviceaccount.com",
universe_domain: "googleapis.com",
```

Software qualities impacted

Security Blocker ▾

Code attribute

Responsibility | Not trustworthy

Security Hotspot:

Allowing requests with excessive content length is security-sensitive [typescript:S5693](#)

Status: To review

This security hotspot needs to be reviewed to assess whether the code poses a risk.

Review

Where is the risk?

What's the risk?

Assess the risk

How can I fix it?

Activity

src/helpers/fileUploader.ts

Open in IDE

⌵ Show previous few lines of code

96 destination: function (req, file, cb) {

97 cb(null, uploadsDir);

98 },

99 filename: function (req, file, cb) {

100 const uniqueName = `\${Date.now()}-\${file.originalname}`;

101 cb(null, uniqueName);

102 },

103 });

104

105 // Multer middleware

106 const upload = multer({ storage, fileFilter });

107

108 const profileImage = upload.single("profileImage");

109

110 const uploadMessageImages = upload.array("messageImages", 40);

111 const newsImage = upload.array("image", 40);

112 const advertiseVideo = upload.single("advertiseVideo");

113 const invertorRelationImage = upload.single("invertorRelationImage");

114 const attachmentFiles = upload.fields([

115 { name: "attachments", maxCount: 10 },

116]);

⌵ Show next few lines of code

Make sure the content length limit is safe here.

Using http protocol is insecure. Use https instead.

Using clear-text protocols is security-sensitive [typescript:S5332](#)

Status: To review

This security hotspot needs to be reviewed to assess whether the code poses a risk.

Review

Where is the risk?

What's the risk?

Assess the risk

How can I fix it?

Activity

src/helpers/emailSender.ts

Open in IDE

1 import nodemailer from "nodemailer";

2 import config from "../config";

3 import ApiError from "../errors/ApiErrors";

4

5 const emailSender = async (subject: string, email: string, html: string) => {

6 const transporter = nodemailer.createTransport({

7 service: "gmail",

8 host: "smtp.gmail.com",

9 port: 587,

10 secure: false, // true for 465, false for other ports

11 auth: {

12 user: config.send_email.nodemailer_email,

13 pass: config.send_email.nodemailer_password,

14 },

15 });

16 //

⌵ Show next few lines of code

Using http protocol is insecure. Use https instead.

Category: Denial of Service (DoS)

Assignee: Not assigned

Review priority: Low

Category: Encryption of Sensitive Data

Assignee: Not assigned

Make sure that enabling CORS is safe here. 

Having a permissive Cross-Origin Resource Sharing policy is security-sensitive [typescript:S5122](#) 

Status: To review

This security hotspot needs to be reviewed to assess whether the code poses a risk.

Review

Where is the risk? What's the risk? Assess the risk How can I fix it? Activity

src/app.ts



Open in IDE

Show previous few lines of code

```
25 // AWS / Reverse Proxy setup
26 app.set("trust proxy", true);
27
28 export const corsOptions = {
29   // origin: [
30     // "http://localhost:5173",
31     // "http://localhost:3000",
32     // "https://timothy-dashboard.netlify.app",
33     // "https://timothy-dashboard.vercel.app",
34   // ],
35   origin: "*",
36   methods: ["GET", "POST", "PUT", "DELETE", "PATCH"],
37   allowedHeaders: ["Content-Type", "Authorization"],
38   credentials: true,
39 };
40
41 app.use(
42   bodyParser.json({
43     verify: function (
44       req: express.Request,
45       res: express.Response,
46       buf: Buffer,
47     ) {
48       req.rawBody = buf;
49     },
50   }),
51 );
52
53 app.use(cors(corsOptions));
```

Make sure that enabling CORS is safe here.

Review priority:

Low

Category:

Insecure Configuration

Assignee:

Not assigned



Reliability Issues:

Prefer `Number.isNaN` over `isNaN`.

Number static methods and properties should be preferred over global equivalents [typescript:S7773](#)

Line affected: L190 • Effort: 2min • Introduced: 13 hours ago

Open ▾ Not assigned ▾ convention ... + Quick fix

Where is the issue? Why is this an issue? Activity

Software qualities impacted

Reliability Medium ▾

Maintainability Low ▾

Code attribute

Consistency | Not conventional

Scholarstika > src/app/modules/FeesManagement/fees_management.services.ts

Open in IDE See all issues in this file

⌵ Show previous few lines of code ⌵ Show all lines

185);
186 }
187
188 const paidAmount = Number(payload.paidAmount);
189
190 if (isNaN(paidAmount) || paidAmount <= 0) {

Prefer `Number.isNaN` over `isNaN`.

191 throw new ApiError(HttpStatus.BAD_REQUEST, "Invalid paid amount");
192 }
193
194 return await prisma.\$transaction(async (tx) => {
195
196 const student = await tx.student.findFirstOrThrow({
197 where: {
198 studentId: payload.studentId,
199 isVerified: true,

⌵ Show next few lines of code ⌵ Show all lines

Prefer 'Number.isNaN' over 'isNaN'.

Number static methods and properties should be preferred over global equivalents [typescript:S773](#)

Line affected: L370 • Effort: 2min • Introduced: 13 hours ago

Open Not assigned convention Quick fix

Where is the issue? Why is this an issue? Activity

Scholarstika > src/app/modules/Branch_Management/branch_management.services.ts

Open in IDE See all issues in this file

Show previous few lines of code Show all lines

365
366
367
368
369
370

371
372
373
374

375
376
377
378
379

```
    });  
  }  
  if (joinDateFrom || joinDateTo) {  
    const dateFilter: any = {};  
  
    if (joinDateFrom && !isNaN(Date.parse(joinDateFrom as string))) {  
  
      dateFilter.gte = new Date(joinDateFrom as string);  
    }  
  
    if (joinDateTo && !isNaN(Date.parse(joinDateTo as string))) {  
  
      dateFilter.lte = new Date(joinDateTo as string);  
    }  
  
    if (Object.keys(dateFilter).length > 0) {  
      extraFilters.push({ joinDate: dateFilter });  
    }  
  }  
}
```

Prefer 'Number.isNaN' over 'isNaN'.

Prefer 'Number.isNaN' over 'isNaN'.

Show next few lines of code Show all lines

Software qualities impacted

Reliability Medium

Maintainability Low

Code attribute

Consistency Not conventional

Prefer 'Number.isNaN' over 'isNaN'.

Number static methods and properties should be preferred over global equivalents [typescript:S773](#)

Line affected: L87 • Effort: 2min • Introduced: 13 hours ago

Open Not assigned convention Quick fix

Where is the issue? Why is this an issue? Activity

Scholarstika > src/app/modules/Teacher/Teacher.validation.ts

Open in IDE See all issues in this file

Show previous few lines of code Show all lines

82
83
84
85
86
87

88
89
90
91
92
93
94
95
96

```
body: z.object({  
  attendanceDate: z  
    .string({  
      required_error: "attendanceDate is required",  
    })  
    .refine((date) => !isNaN(Date.parse(date)), {  
  
    message: "Invalid date format",  
  }  
}),  
  
  subscriptionId: z  
    .string({  
      required_error: "subscriptionId is required",  
    })  
}
```

Prefer 'Number.isNaN' over 'isNaN'.

Show next few lines of code Show all lines

Software qualities impacted

Reliability Medium

Maintainability Low

Code attribute

Consistency Not conventional

Prefer `String#replaceAll()` over `String#replace()`.

Strings should use "replaceAll()" instead of "replace()" with global regex [typescript:S7781](#) 

Line affected: L26 • Effort: 5min • Introduced: 13 hours ago

Open ▾ Not assigned ▾ readability ... +  Quick fix

Where is the issue? Why is this an issue? Activity

Software qualities impacted

Reliability  Low ▾

Maintainability  Low ▾

Code attribute

Intentionality | Not clear

Scholarstika > src/app/modules/Testimonials/testimonials.services.ts 

Open in IDE

[See all issues in this file](#)

⌕ Show previous few lines of code

⌕ Show all lines

```
21
22   const payload = {
23     ...bodyData,
24     ...(file?.path && {
25       videoUrl: file.path
26         .replace(/\\/g, "/")
27
28         .replace(process.cwd().replace(/\\/g, "/") + "/", "").
29
30     });
31   };
32   const result=await prisma.testimonials.create({
33     data:payload
34   });
35   if(!result){
36     throw new ApiError(HttpStatus.NOT_EXTENDED,'issues by the Testimonials create section')
```

⌕ Show next few lines of code

⌕ Show all lines

Prefer `Number.parseInt` over `parseInt`.

Number static methods and properties should be preferred over global equivalents [typescript:S7773](#) 

Line affected: L370 • Effort: 2min • Introduced: 13 hours ago

Software qualities impacted

Reliability  Medium 

Maintainability  Low 

Code attribute

Consistency | Not conventional

Open  Not assigned  convention    Quick fix

Where is the issue? Why is this an issue? Activity

Scholarstika > src/app/modules/User/user.service.ts 

Open in IDE

[See all issues in this file](#)

 Show previous few lines of code

 Show all lines

```
365
366
367
368   const getUserGrowthIntoDb = async (query: { year?: string }) => {
369     try {
370       const year = query.year ? parseInt(query.year) : new Date().getFullYear();
371
372       const previousYear = year - 1;
373
374       const startOfYear = new Date(`${year}-01-01T00:00:00.000Z`);
375       const endOfYear = new Date(`${year}-12-31T23:59:59.999Z`);
376
377       const startOfPrevYear = new Date(`${previousYear}-01-01T00:00:00.000Z`);
378       const endOfPrevYear = new Date(`${previousYear}-12-31T23:59:59.999Z`);
379
380       const currentYearUsers = await prisma.user.findMany({
```

 Show next few lines of code

 Show all lines

Prefer `Number.parseInt` over `parseInt`.

Prefer `String#replaceAll()` over `String#replace()`.

Strings should use "replaceAll()" instead of "replace()" with global regex [typescript:S7781](#) 

Line affected: L136 • Effort: 5min • Introduced: 13 hours ago

Software qualities impacted

Reliability  Low 

Maintainability  Low 

Code attribute

Intentionality | Not clear

Open  Not assigned  readability    Quick fix

Where is the issue? Why is this an issue? Activity

Scholarstika > src/helpers/fileUploader.ts 

Open in IDE

[See all issues in this file](#)

 Show previous few lines of code

 Show all lines

```
131
132  /**
133   * Converts an absolute local file path to a normalized relative URL.
134   * e.g. "R:/project/uploads/123-video.mp4" → "/uploads/123-video.mp4"
135   */
136   const toRelativePath = (absolutePath: string): string => {
137     const normalized = absolutePath.replace(/\\/g, "/"); // fix Windows backslashes
138
139     const uploadsIndex = normalized.indexOf("/uploads/");
140     if (uploadsIndex !== -1) {
141       return normalized.slice(uploadsIndex); // "/uploads/filename.mp4"
142     }
143     // fallback: just return the filename under /uploads/
144     return `/uploads/${path.basename(normalized)}`;
145   };
146
147   // Cloudinary uploader function
```

 Show next few lines of code

 Show all lines

Prefer `String#replaceAll()` over `String#replace()`.

Prefer `String#replaceAll()` over `String#replace()`.

Strings should use "replaceAll()" instead of "replace()" with global regex [typescript:S7781](#) 

Line affected: L44 • Effort: 5min • Introduced: 13 hours ago

Software qualities impacted

Reliability  Low 

Maintainability  Low 

Code attribute

Intentionality | Not clear

Open  Not assigned  readability    Quick fix

Where is the issue? Why is this an issue? Activity

Scholarstika > src/utls/emailcontext/sendvarificationData.ts 

Open in IDE See all issues in this file

Show previous few lines of code Show all lines

39 // Utilities
40 // =====
41 const currentYear = new Date().getFullYear();
42
43 // Escape username to prevent HTML injection
44 const escapedUsername = username.replace(/[<>"]/g, (char) => {

Prefer `String#replaceAll()` over `String#replace()`.

45 const escapeMap: Record<string, string> = {
46 '<': '<',
47 '>': '>',
48 '&': '&',
49 '"': '"',
50 };
51 return escapeMap[char] || char;
52 });
53

Show next few lines of code Show all lines

Prefer `String#replaceAll()` over `String#replace()`.

Strings should use "replaceAll()" instead of "replace()" with global regex [typescript:S7781](#) 

Line affected: L76 • Effort: 5min • Introduced: 13 hours ago

Software qualities impacted

Reliability  Low 

Maintainability  Low 

Code attribute

Intentionality | Not clear

Open  Not assigned  readability    Quick fix

Where is the issue? Why is this an issue? Activity

Scholarstika > src/utls/uploadToS3.ts 

Open in IDE See all issues in this file

Show previous few lines of code Show all lines

71
72 // Multer disk storage (local temporary before S3 upload)
73 const storage = multer.diskStorage({
74 destination: (req, file, cb) => cb(null, uploadsDir),
75 filename: (req, file, cb) =>
76 cb(null, `\${Date.now()}-\${file.originalname.replace(/\\s+/g, "-")}`);

Prefer `String#replaceAll()` over `String#replace()`.

77 });
78 // Multer middleware
79 const upload = multer({ storage, fileFilter });
80
81 // Different upload groups
82 const profileImage = upload.single("profileImage");
83 const hotelLogo = upload.single("businessLogo");
84 const hotelImages = upload.array("hotelImages", 5);
85 const hotelRoomImages = upload.array("hotelRoomImages", 5);

Show next few lines of code Show all lines

Maintainability:

Remove this commented out code. 

Sections of code should not be commented out [typescript:S125](#) 

Line affected: L28 • Effort: 5min • Introduced: 13 hours ago

Open  Not assigned  unused   Quick fix

Software qualities impacted

Maintainability  Medium 

Code attribute

Intentionality | Not clear

- Where is the issue?
- Why is this an issue?
- Activity

 Show previous few lines of code

23

24

25

26

27

28

29

30

31

32

33

34

35

```
console.log("Creating super admin with email:");
// await prisma.$transaction(async (TransactionClient) => {
//   const hashedPassword: string = await bcrypt.hash(payload.password, 12);

//   await TransactionClient.user.create({
//     data: {
//       fullName: payload.fullName,
//       email: payload.email,
//       password: hashedPassword,
//       role: payload.role,
//     },
//   });
// });
```

Remove this commented out code.

```
// await TransactionClient.admin.create({
//   data: {
//     email: payload.email,
//     password: hashedPassword,
//   },
// });
// });
} catch (err) {
```

 Show next few lines of code

 Show all lines

Remove this commented out code.

Sections of code should not be commented out [typescript:S125](#) 

Line affected: L2 • Effort: 5min • Introduced: 13 hours ago

Open ▾ Not assigned ▾ unused +  Quick fix

- Where is the issue?
- Why is this an issue?
- Activity

Software qualities impacted

Maintainability  Medium ▾

Code attribute

Intentionality | Not clear

Scholarstika > src/app/db/db.ts 

Open in IDE [See all issues in this file](#)

```
1      import { UserRole } from "@prisma/client";
2      // import bcrypt from "bcrypt";
3
4      import prisma from "../../shared/prisma";
5
6      export const initiateSuperAdmin = async () => {
7        const payload = {
8          fullName: "Super Admin",
9          userName: "superAdmin",
10         email: "superadmin@gmail10p.com",
11         password: "123456",
12         role: UserRole.SUPER_ADMIN,
```

Show next few lines of code

Show all lines

Remove this commented out code.